

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



**TIỂU LUẬN KẾT THÚC MÔN
BẢO MẬT TRONG IOT**

SINH VIÊN THỰC HIỆN:

Huỳnh Bùi Hoàng Ân – 231A010372

LỚP HỌC PHẦN: 253INT441001

GIẢNG VIÊN: Ths. HỒ NHỰT MINH

THÀNH PHỐ HỒ CHÍ MINH 25/ 07/ 2026

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



ĐỀ TÀI:

RỦI RO MẬT KHẨU MẠC ĐỊNH TRÊN THIẾT BỊ IOT

SINH VIÊN THỰC HIỆN:

Huỳnh Bùi Hoàng Ân – 231A010372

LỚP HỌC PHẦN: 253INT441001

GIẢNG VIÊN: Ths. HỒ NHỰT MINH

THÀNH PHỐ HỒ CHÍ MINH 03/08/2026

LỜI CAM KẾT VỀ SỬ DỤNG TRÍ TUỆ NHÂN TẠO (AI)

Tôi xin cam kết và minh bạch tuyên bố rằng, trong suốt quá trình thực hiện bài tiểu luận này, tôi có sử dụng công cụ Trí tuệ nhân tạo (AI), ChatGPT (OpenAI) để hỗ trợ cho các công việc sau:

Hiệu đính ngữ pháp, trau chuốt câu chữ và cải thiện phong cách diễn đạt trong báo cáo.

Gợi ý cấu trúc dàn ý và bố cục các chương.

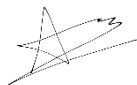
Hỗ trợ tìm kiếm và tổng hợp tài liệu tham khảo từ các nguồn mở.

Tôi khẳng định rằng công cụ AI trên chỉ đóng vai trò hỗ trợ kỹ thuật, không tham gia vào việc hình thành ý tưởng cốt lõi, phương pháp nghiên cứu, phân tích dữ liệu, hay đưa ra kết luận của công trình. Toàn bộ nội dung học thuật, thiết kế hệ thống, mã nguồn, số liệu kiểm thử và nhận định đều do tôi tự thực hiện dựa trên năng lực và sự nỗ lực của bản thân.

Tôi hoàn toàn chịu trách nhiệm về tính nguyên bản, tính chính xác học thuật và tính trung thực của toàn bộ bài tiểu luận này.

TP..Hồ Chí Minh, ngày 03 tháng 08 năm 2026

Sinh viên thực hiện



Huỳnh Bùi Hoàng Ân

LỜI NHẬN XÉT

This image shows a full page of white paper with horizontal dotted lines. The lines are evenly spaced and run across the width of the page, providing a guide for handwriting practice. There are no margins, text, or other markings on the page.

MỤC LỤC

LỜI CAM KẾT VỀ SỬ DỤNG TRÍ TUỆ NHÂN TẠO (AI)	i
LỜI NHẬN XÉT	ii
DANH MỤC BẢNG.....	v
DANH MỤC HÌNH ẢNH	vi
CHƯƠNG 1 MỞ ĐẦU	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Phát biểu vấn đề	1
1.3. Mục tiêu	2
1.4. Đối tượng và phạm vi	2
1.5. Sản phẩm dự kiến và đóng góp	3
1.6. Cấu trúc báo cáo.....	3
CHƯƠNG 2 CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN	4
2.1. Kiến trúc và bối cảnh kỹ thuật của hệ thống.....	4
2.2. Khái niệm bảo mật	5
2.3. Nội dung cần nhấn mạnh theo nhóm đề tài.....	6
2.3.1. Điều kiện xảy ra	6
2.3.2. Mô hình tấn công	6
2.3.3 Nguyên nhân – điều kiện – hậu quả	7
2.3.4. Tác động đối với hệ thống	8
2.3.5. Biện pháp phòng chống.....	8
2.4. Chuẩn, công cụ và nguồn GitHub chính	9
2.5. Công trình hoặc giải pháp liên quan	11
2.6. Tiểu kết Chương 2	12
CHƯƠNG 3 PHƯƠNG PHÁP VÀ THIẾT KẾ.....	13
3.1. Phương pháp thực hiện	13
3.2. Kiến trúc và luồng dữ liệu.....	13
3.3. Môi trường, công cụ và dữ liệu.....	14

3.4. Quy trình thực hiện	15
3.5. Tiêu chí đánh giá.....	15
3.6. Đạo đức và an toàn trong nghiên cứu	15
CHƯƠNG 4 TRIỂN KHAI VÀ SẢN PHẨM	17
4.1. Chuẩn bị môi trường	17
4.2. Thành phần sản phẩm	17
4.3. Kịch bản thử nghiệm.....	18
4.4. Kết quả triển khai.....	19
4.5. Thảo luận và hạn chế	22
4.5.1. Thảo luận.....	22
4.5.2. Hạn chế	23
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	24
5.1. Tài sản và dữ liệu cần bảo vệ.....	24
5.2. Môi đe dọa và lỗ hổng.....	24
5.3. Ma trận đánh giá rủi ro.....	25
5.4. Biện pháp giảm thiểu và ưu tiên	26
5.4.1. Checklist chính sách mật khẩu.....	27
5.4.2 Đối chiếu với OWASP IoT Top Risks và OWASP ISVS	27
5.5. Rủi ro còn lại.....	28
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	29
6.1. Kết luận	29
6.2. Hạn chế	30
6.3. Hướng phát triển	30
TÀI LIỆU THAM KHẢO.....	31
PHỤ LỤC.....	32

DANH MỤC BẢNG

Bảng 2.1: Bảng khái niệm bảo mật	6
Bảng 2.2: Phân tích nguyên nhân và hậu quả của lỗ hổng mật khẩu mặc định	8
Bảng 2.3: Ma trận STRIDE – Rủi ro đối với đề tài	9
Bảng 2.4: Chuẩn, tài liệu và công cụ sử dụng trong đề tài.....	11
Bảng 2.5: So sánh các công trình liên quan	11
Bảng 3.1: Môi trường, công cụ và dữ liệu sử dụng trong nghiên cứu	14
Bảng 3.2: Quy trình thực hiện đề tài	15
Bảng 3.3: Tiêu chí đánh giá	15
Bảng 4.1: Môi trường triển khai.....	17
Bảng 4.2: Thành phần sản phẩm.	18
Bảng 4.3: Kịch bản thử nghiệm và đánh giá	19
Bảng 4.4: Kết quả thử nghiệm.....	20
Bảng 5.1: Danh sách tài sản và dữ liệu cần bảo vệ	24
Bảng 5.2: Phân tích mối đe dọa và lỗ hổng.....	25
Bảng 5.3: Ma trận đánh giá rủi ro	26
Bảng 5.4: Biện pháp giảm thiểu	27
Bảng 5.5: Đối chiếu kết quả nghiên cứu với OWASP IoT Project và OWASP ISVS	28
Bảng 6.1: Đối chiếu mục tiêu nghiên cứu với kết quả thực hiện.	30

DANH MỤC HÌNH ẢNH

Hình 2.1: Kiến trúc tổng quan của hệ thống nghiên cứu	4
Hình 2.2: Data Flow Diagram (DFD) của hệ thống nghiên cứu.....	5
Hình 2.3: Attack Tree khai thác mật khẩu mặc định.....	7
Hình 3.1. Mô hình hệ thống nghiên cứu và các điểm rủi ro liên quan đến mật khẩu mặc định trên thiết bị IoT.	14
Hình 4.1: Ảnh môi trường chạy Docker.....	17
Hình 4.2: Đăng nhập thành công bằng tài khoản mặc định.	20
Hình 4.3: Thay đổi mật khẩu quản trị.	20
Hình 4.4: Nhiều lần đăng nhập sai nhưng hệ thống vẫn cho phép thử lại.	21
Hình 4.5: Đăng nhập SSH thành công.	22
Hình 4.6: Kết quả lệnh id.	22
Hình 5.1: Ma trận Risk Matrix 5×5	26

DANH MỤC TỪ VIẾT TẮT

Viết tắt	Ý nghĩa
AI	Artificial Intelligence (Trí tuệ nhân tạo)
ATTT	An toàn thông tin
CIA	Confidentiality – Integrity – Availability (Bảo mật – Toàn vẹn – Sẵn sàng)
CVSS	Common Vulnerability Scoring System
DFD	Data Flow Diagram (Sơ đồ luồng dữ liệu)
HTTPS	HyperText Transfer Protocol Secure
IoT	Internet of Things (Internet vạn vật)
ISVS	IoT Security Verification Standard
MFA	Multi-Factor Authentication (Xác thực đa yếu tố)
MQTT	Message Queuing Telemetry Transport
NIST	National Institute of Standards and Technology
OWASP	Open Worldwide Application Security Project
README	Read Me (Tài liệu hướng dẫn sử dụng dự án)
Risk Matrix	Mã trận đánh giá rủi ro
SSH	Secure Shell
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
TLS	Transport Layer Security
VPN	Virtual Private Network

CHƯƠNG 1 MỞ ĐẦU

1.1. Bối cảnh và lý do chọn đề tài

Sự phát triển nhanh chóng của Internet of Things (IoT) đã tạo ra nhiều ứng dụng trong đời sống và sản xuất như nhà thông minh, y tế thông minh, công nghiệp thông minh và nông nghiệp thông minh. Các thiết bị IoT thường được kết nối Internet để thu thập dữ liệu, trao đổi thông tin và cho phép người dùng điều khiển từ xa. Tuy nhiên, cùng với sự phát triển đó là nhiều vấn đề về an toàn thông tin, đặc biệt khi nhiều thiết bị được đưa vào sử dụng nhưng chưa được cấu hình bảo mật đầy đủ.

Một trong những nguyên nhân phổ biến dẫn đến mất an toàn là việc thiết bị vẫn sử dụng tài khoản và mật khẩu mặc định (Default Password) sau khi cài đặt. Để đơn giản hóa quá trình cấu hình ban đầu, nhiều nhà sản xuất cung cấp sẵn tài khoản và mật khẩu mặc định cho tất cả các thiết bị cùng dòng sản phẩm. Nếu người dùng không thay đổi các thông tin này, kẻ tấn công có thể dễ dàng truy cập trái phép bằng cách sử dụng các danh sách tài khoản mặc định được công khai trên Internet hoặc trong tài liệu hướng dẫn của thiết bị.

Sau khi đăng nhập thành công, kẻ tấn công có thể thay đổi cấu hình, truy cập dữ liệu, cài đặt phần mềm độc hại hoặc chiếm quyền điều khiển thiết bị. Trong nhiều trường hợp, các thiết bị bị chiếm quyền còn có thể bị lợi dụng để tham gia vào mạng botnet, điển hình như cuộc tấn công của mã độc Mirai.

Theo OWASP IoT Top 10, việc sử dụng thông tin xác thực mặc định hoặc thông tin xác thực yếu là một trong những nguyên nhân gây mất an toàn phổ biến trên các thiết bị IoT. Vì vậy, đề tài "Phân tích rủi ro của mật khẩu mặc định trên thiết bị IoT sử dụng OWASP IoTGoat" được thực hiện nhằm phân tích nguyên nhân hình thành lỗ hổng, đánh giá các rủi ro đối với hệ thống và đề xuất các biện pháp giảm thiểu phù hợp.

1.2. Phát biểu vấn đề

Mật khẩu mặc định là thông tin xác thực được nhà sản xuất thiết lập sẵn trước khi thiết bị được phân phối đến người sử dụng. Trong thực tế, nhiều người dùng không thay đổi mật khẩu mặc định sau khi cài đặt, làm tăng nguy cơ bị truy cập trái phép.

Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể đăng nhập vào giao diện quản trị hoặc dịch vụ SSH của thiết bị, từ đó thay đổi cấu hình, truy cập thông tin quản trị hoặc chiếm quyền điều khiển thiết bị. Ngoài ra, nếu hệ thống không giới hạn số lần đăng nhập sai, thiết bị còn có nguy cơ bị tấn công dò mật khẩu (Brute Force). Trong một số trường hợp, việc sử dụng Hard-coded Credential trong firmware cũng làm tăng khả năng bị khai thác nếu thông tin xác thực bị lộ.

Các nguy cơ trên ảnh hưởng trực tiếp đến ba thuộc tính của mô hình CIA (Confidentiality, Integrity và Availability), làm giảm mức độ an toàn của hệ thống IoT.

- Để giải quyết vấn đề trên, đề tài tập trung trả lời các câu hỏi nghiên cứu sau:

- Những nguyên nhân nào dẫn đến việc thiết bị IoT bị khai thác thông qua mật khẩu mặc định?
- Những tài sản nào của hệ thống bị ảnh hưởng khi lỗ hổng bị khai thác?
- Các kịch bản tấn công có thể được mô phỏng như thế nào trên môi trường OWASP IoTGoat?
- Những biện pháp kỹ thuật và chính sách nào giúp giảm thiểu các rủi ro liên quan đến mật khẩu mặc định?
- Những biện pháp kỹ thuật và chính sách nào có thể giảm thiểu rủi ro này?

1.3. Mục tiêu

Đề tài hướng đến năm mục tiêu chính sau đây:

MT-01. Phân tích nguyên nhân hình thành và điều kiện tồn tại của lỗ hổng mật khẩu mặc định trên thiết bị IoT.

Đầu ra: Báo cáo phân tích nguyên nhân và điều kiện khai thác.

MT-02. Xây dựng mô hình phân tích gồm Data Flow Diagram (DFD), Attack Tree và ma trận STRIDE để xác định các mối đe dọa đối với hệ thống.

Đầu ra: DFD, Attack Tree và STRIDE Matrix.

MT-03. Triển khai môi trường mô phỏng OWASP IoTGoat trên Docker và thực hiện các kịch bản thử nghiệm liên quan đến mật khẩu mặc định.

Đầu ra: Môi trường thực nghiệm và kết quả các kịch bản TC-01 đến TC-04.

MT-04. Đánh giá mức độ ảnh hưởng của lỗ hổng đối với các tài sản của hệ thống thông qua Asset Inventory và Risk Matrix.

Đầu ra: Asset Inventory và bảng đánh giá rủi ro.

MT-05. Đề xuất các biện pháp giảm thiểu và xây dựng checklist chính sách mật khẩu theo các khuyến nghị của OWASP.

Đầu ra: Checklist chính sách mật khẩu và danh sách các biện pháp giảm thiểu.

1.4. Đối tượng và phạm vi

Đối tượng nghiên cứu

- Lỗ hổng mật khẩu mặc định trên thiết bị IoT.
- Hard-coded Credential và cơ chế xác thực bằng tên đăng nhập, mật khẩu.
- Môi trường mô phỏng OWASP IoTGoat.
- Các khuyến nghị bảo mật của OWASP và NIST liên quan đến quản lý thông tin xác thực.

Phạm vi nghiên cứu

Đề tài được thực hiện trên môi trường mô phỏng sử dụng Docker và OWASP IoTGoat nhằm tái hiện các tình huống liên quan đến mật khẩu mặc định. Nội dung nghiên cứu tập trung vào phân

tích rủi ro, xây dựng mô hình mối đe dọa, thực hiện các kịch bản thử nghiệm và đề xuất biện pháp giảm thiểu.

Đề tài không nghiên cứu các cơ chế bảo mật khác như Secure Boot, mã hóa dữ liệu, cập nhật firmware an toàn, giao thức truyền thông bảo mật hoặc xác thực đa yếu tố. Tất cả các thử nghiệm chỉ được thực hiện trên môi trường mô phỏng phục vụ mục đích học tập và nghiên cứu, không áp dụng trên các hệ thống hoặc thiết bị thực tế.

1.5. Sản phẩm dự kiến và đóng góp

Đề tài hướng đến các sản phẩm sau:

- Báo cáo phân tích rủi ro mật khẩu mặc định trên thiết bị IoT.
- Sơ đồ Data Flow Diagram (DFD), Threat Model và Attack Tree.
- Ma trận STRIDE và Risk Matrix.
- Danh sách tài sản cần bảo vệ (Asset Inventory).
- Bảng nguyên nhân – hậu quả – biện pháp giảm thiểu.
- Checklist chính sách mật khẩu gồm tối thiểu 15 tiêu chí.
- Kho lưu trữ GitHub chứa mã nguồn, README, hình ảnh minh chứng và tài liệu tham khảo.

Các sản phẩm trên không chỉ đáp ứng yêu cầu của học phần mà còn có thể được sử dụng làm tài liệu tham khảo trong quá trình học tập, nghiên cứu và đánh giá an toàn thông tin đối với các hệ thống IoT quy mô nhỏ.

1.6. Cấu trúc báo cáo

Báo cáo gồm 06 chương, được tổ chức như sau:

Chương 1. Mở đầu: Trình bày bối cảnh nghiên cứu, lý do chọn đề tài, phát biểu vấn đề, mục tiêu nghiên cứu, đối tượng và phạm vi nghiên cứu, các sản phẩm dự kiến và cấu trúc báo cáo.

Chương 2. Cơ sở lý thuyết: Giới thiệu các khái niệm về Internet of Things (IoT), cơ chế xác thực, mật khẩu mặc định, Hard-coded Credential, mô hình CIA, STRIDE và các khuyến nghị của OWASP liên quan đến bảo mật thiết bị IoT.

Chương 3. Phương pháp và thiết kế: Trình bày phương pháp nghiên cứu, mô hình hệ thống, sơ đồ DFD, Attack Tree, môi trường thực nghiệm, công cụ sử dụng và quy trình triển khai.

Chương 4. Triển khai và sản phẩm: Mô tả quá trình xây dựng môi trường IoTGoat trên Docker, các kịch bản thử nghiệm, kết quả thực nghiệm và những hạn chế trong quá trình triển khai.

Chương 5. Đánh giá bảo mật: Phân tích tài sản cần bảo vệ, các mối đe dọa, ma trận STRIDE, Risk Matrix, checklist chính sách mật khẩu, đối chiếu với các khuyến nghị của OWASP và đề xuất biện pháp giảm thiểu.

Chương 6. Kết luận và hướng phát triển: Tổng kết kết quả nghiên cứu, đánh giá mức độ hoàn thành mục tiêu, nêu các hạn chế và đề xuất hướng phát triển trong tương lai.

Link GitHub dự án: <https://github.com/hoangan1207/iot-default-password-risk>

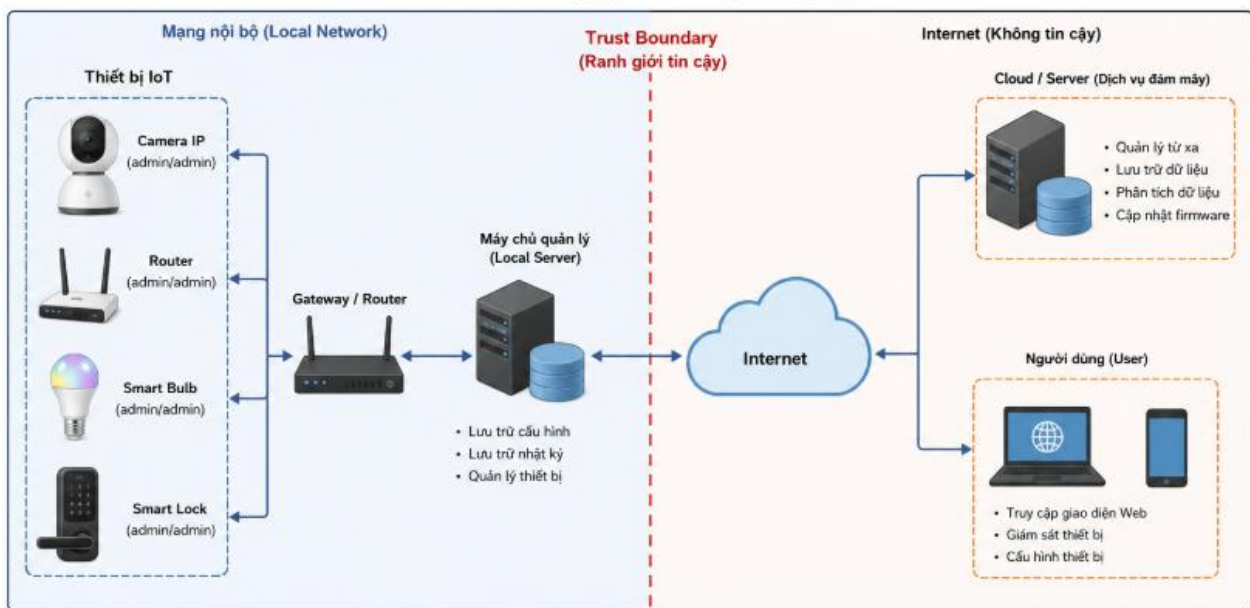
CHƯƠNG 2 CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN

2.1. Kiến trúc và bối cảnh kỹ thuật của hệ thống

Internet of Things (IoT) là mô hình kết nối các thiết bị vật lý với Internet nhằm thu thập, trao đổi và xử lý dữ liệu. Trong đề tài này, hệ thống gồm các thành phần chính: thiết bị IoT, người dùng, mạng nội bộ, Internet và máy chủ quản lý (Cloud/Server). Người dùng truy cập giao diện Web để cấu hình và quản lý thiết bị, trong khi thiết bị trao đổi dữ liệu với máy chủ thông qua mạng.

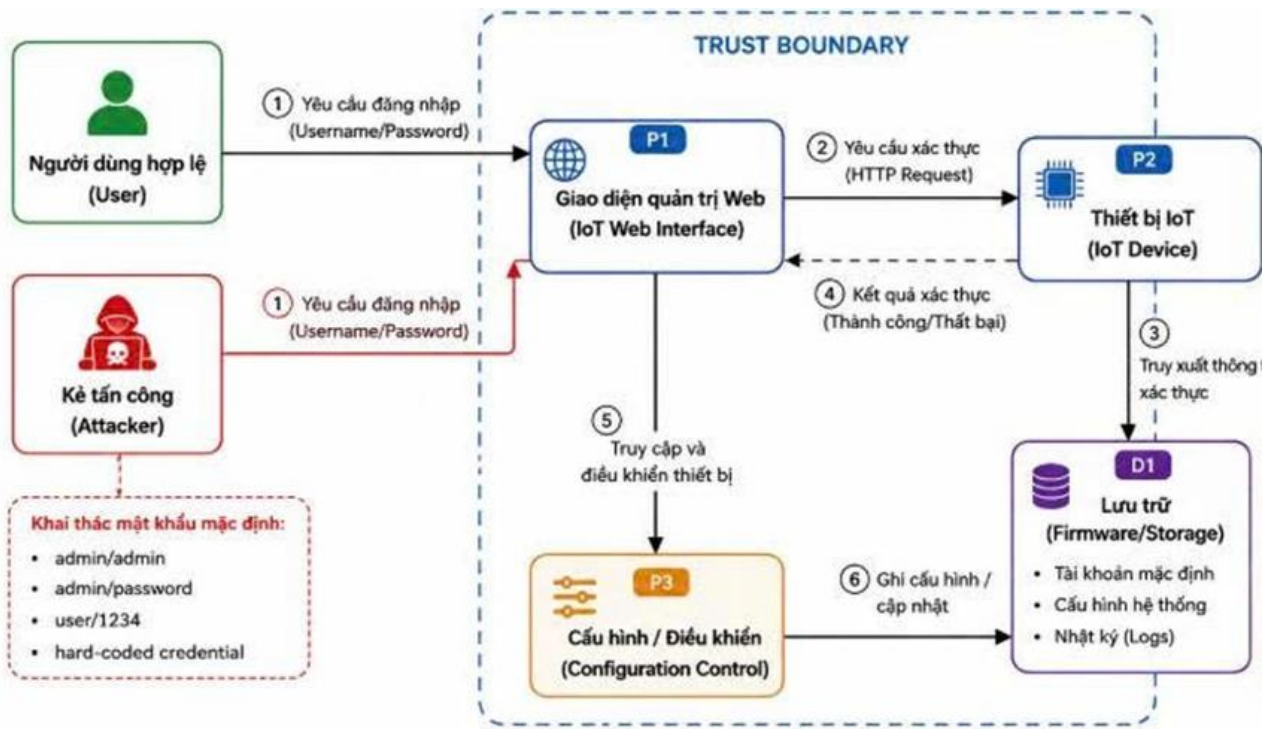
Đối với lỗ hổng mật khẩu mặc định, điểm cần bảo vệ là cơ chế xác thực giữa người dùng và thiết bị. Nếu thiết bị vẫn sử dụng tài khoản mặc định hoặc tồn tại Hard-coded Credential, kẻ tấn công có thể đăng nhập trái phép và chiếm quyền điều khiển thiết bị.

Trong phạm vi đề tài, hệ thống được mô phỏng bằng OWASP IoTGoat chạy trên Docker nhằm tái hiện các tình huống liên quan đến mật khẩu mặc định và Hard-coded Credential. Môi trường này giúp đánh giá các nguy cơ bảo mật trong điều kiện an toàn mà không ảnh hưởng đến các hệ thống thực tế.



Hình 2.1: Kiến trúc tổng quan của hệ thống nghiên cứu

Nguồn: ChatGPT (OpenAI), tác giả hiệu chỉnh (2026).



Hình 2.2: Data Flow Diagram (DFD) của hệ thống nghiên cứu.

Nguồn: ChatGPT (OpenAI), tác giả hiệu chỉnh (2026).

2.2. Khái niệm bảo mật

Đề tài sử dụng một số khái niệm bảo mật cơ bản sau:

Khái niệm	Mô tả
Tài sản (Asset)	Thiết bị IoT, tài khoản quản trị, firmware và dữ liệu cấu hình cần được bảo vệ.
Mối đe dọa (Threat)	Các hành vi có thể gây mất an toàn như truy cập trái phép, Brute Force hoặc khai thác Hard-coded Credential.
Lỗ hổng (Vulnerability)	Các điểm yếu như mật khẩu mặc định, mật khẩu dùng chung hoặc không giới hạn số lần đăng nhập sai.
Rủi ro (Risk)	Khả năng mối đe dọa khai thác thành công lỗ hổng và gây ảnh hưởng đến hệ thống.
CIA	Mô hình gồm ba thuộc tính bảo mật: Confidentiality (Bảo mật), Integrity (Toàn vẹn) và Availability (Sẵn sàng).
Authentication	Quá trình xác thực người dùng trước khi cho phép truy cập vào thiết bị hoặc dịch vụ.
STRIDE	Mô hình phân loại mối đe dọa gồm Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service và Elevation of Privilege.

Bảng 2.1: bảng khái niệm bảo mật

Các khái niệm trên là cơ sở để phân tích rủi ro, xây dựng mô hình mối đe dọa và đánh giá mức độ ảnh hưởng của lỗ hổng mật khẩu mặc định trong các chương tiếp theo.

2.3. Nội dung cần nhấn mạnh theo nhóm đề tài

Thiết bị IoT thường được triển khai với tài khoản và mật khẩu mặc định nhằm hỗ trợ quá trình cấu hình ban đầu. Nếu người dùng không thay đổi thông tin xác thực hoặc nhà sản xuất sử dụng Hard-coded Credential, thiết bị sẽ trở thành mục tiêu dễ bị khai thác. Trong nghiên cứu này, việc phân tích tập trung vào điều kiện xảy ra lỗ hổng, mô hình tấn công, tác động đến hệ thống và các biện pháp phòng chống.

2.3.1. Điều kiện xảy ra

Để cuộc tấn công khai thác mật khẩu mặc định thành công, hệ thống thường tồn tại một hoặc nhiều điều kiện sau:

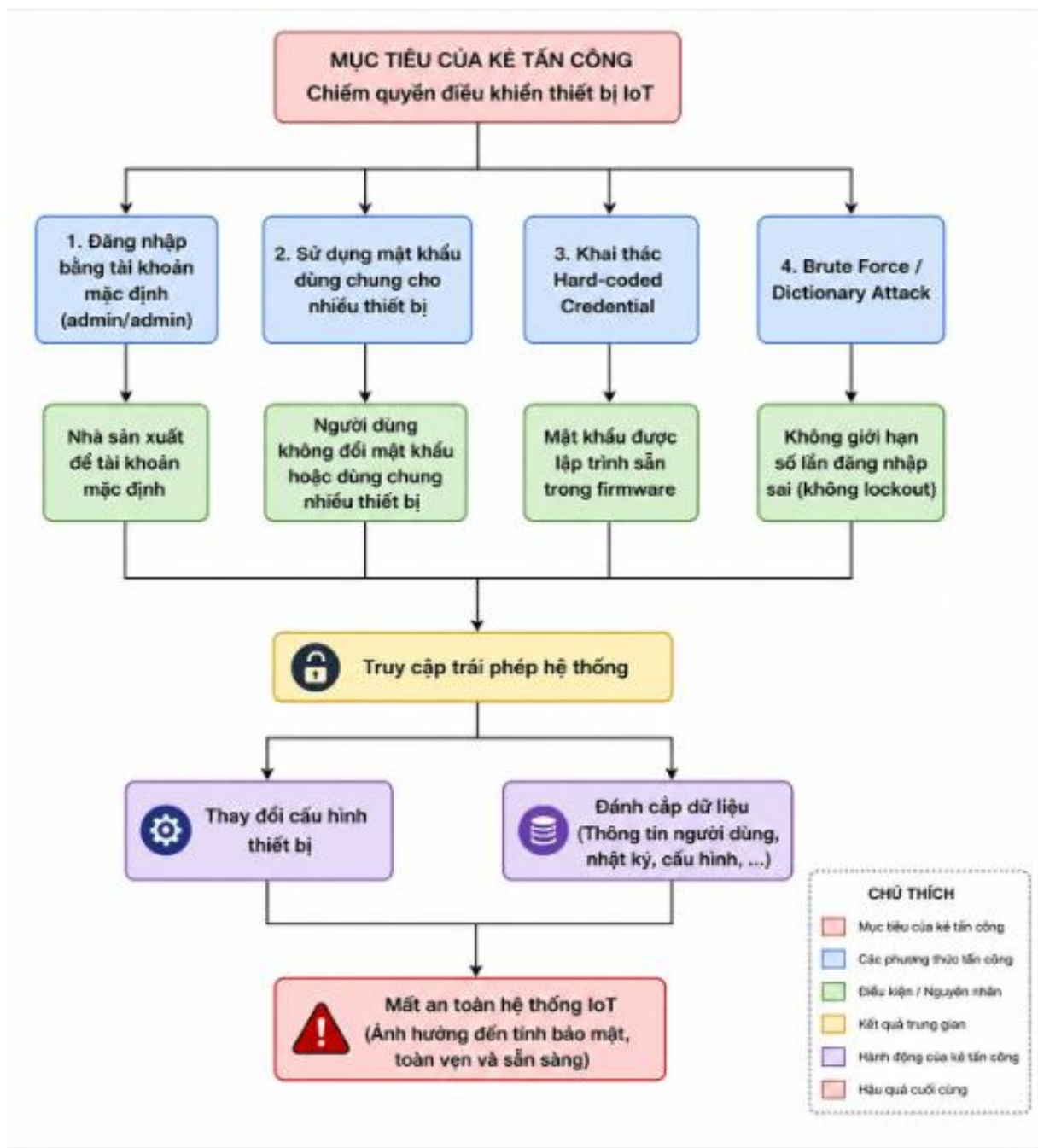
- Thiết bị vẫn sử dụng tài khoản mặc định như admin/admin hoặc admin/password.
- Người dùng không thay đổi mật khẩu sau khi cài đặt.
- Firmware chứa Hard-coded Credential.
- Thiết bị cho phép truy cập giao diện quản trị từ mạng.
- Không giới hạn số lần đăng nhập sai hoặc không khóa tài khoản tạm thời.
- Không ghi nhận đầy đủ nhật ký đăng nhập để phát hiện hành vi bất thường.

Khi các điều kiện trên cùng tồn tại, khả năng thiết bị bị truy cập trái phép sẽ tăng đáng kể. Các điều kiện trên có thể xuất hiện riêng lẻ hoặc đồng thời. Khi nhiều điều kiện cùng tồn tại, nguy cơ thiết bị bị truy cập trái phép sẽ tăng lên đáng kể.

2.3.2. Mô hình tấn công

Kẻ tấn công thực hiện các bước sau để khai thác lỗ hổng:

- Quét mạng để xác định thiết bị IoT đang hoạt động.
- Truy cập giao diện quản trị hoặc dịch vụ đăng nhập.
- Thử tài khoản và mật khẩu mặc định hoặc thực hiện Brute Force.
- Đăng nhập thành công bằng tài khoản mặc định hoặc thông tin xác thực bị lộ.
- Chiếm quyền quản trị, thay đổi cấu hình thiết bị hoặc truy cập trái phép vào dữ liệu quản lý.



Hình 2.3: Attack Tree khai thác mật khẩu mặc định

Nguồn: ChatGPT (OpenAI), tác giả hiệu chỉnh (2026).

2.3.3 Nguyên nhân – điều kiện – hậu quả

STT	Nguyên nhân	Điều kiện xảy ra	Hậu quả
1	Nhà sản xuất sử dụng tài khoản và mật khẩu mặc định cho tất cả thiết bị	Người dùng không thay đổi thông tin đăng nhập sau khi cài đặt	Kẻ tấn công dễ dàng đăng nhập và chiếm quyền quản trị thiết bị

2	Thiết bị không yêu cầu đổi mật khẩu khi đăng nhập lần đầu	Người dùng tiếp tục sử dụng mật khẩu mặc định	Tăng nguy cơ truy cập trái phép và khai thác từ xa
3	Firmware chứa Hard-coded Credential	Kẻ tấn công phân tích firmware hoặc mã nguồn	Lộ thông tin xác thực, khó loại bỏ hoàn toàn lỗ hổng
4	Không giới hạn số lần đăng nhập sai	Kẻ tấn công thực hiện Brute Force	Có thể dò được mật khẩu và chiếm quyền điều khiển thiết bị
5	Không ghi nhận nhật ký đăng nhập	Thiết bị không có cơ chế logging hoặc giám sát	Khó phát hiện, truy vết và điều tra sự cố bảo mật
6	Không cập nhật firmware thường xuyên	Thiết bị vẫn tồn tại các lỗ hổng đã biết	Gia tăng nguy cơ bị khai thác thông qua các lỗ hổng công khai

Bảng 2.2: Phân tích nguyên nhân và hậu quả của lỗ hổng mật khẩu mặc định

Qua bảng phân tích có thể thấy nguyên nhân chủ yếu của lỗ hổng xuất phát từ việc nhà sản xuất sử dụng mật khẩu mặc định để đơn giản hóa quá trình cấu hình ban đầu, trong khi người dùng không thay đổi thông tin xác thực sau khi triển khai thiết bị. Ngoài ra, việc tồn tại Hard-coded Credential, thiếu cơ chế khóa tài khoản sau nhiều lần đăng nhập sai và không ghi nhận đầy đủ nhật ký hệ thống càng làm tăng khả năng bị khai thác.

Hậu quả của lỗ hổng không chỉ dừng lại ở việc truy cập trái phép vào thiết bị mà còn có thể dẫn đến thay đổi cấu hình, đánh cắp dữ liệu, cài đặt mã độc, hình thành mạng botnet hoặc làm gián đoạn hoạt động của toàn bộ hệ thống IoT. Vì vậy, việc loại bỏ mật khẩu mặc định kết hợp với chính sách mật khẩu mạnh, cập nhật firmware định kỳ và áp dụng cơ chế giám sát là những biện pháp cần thiết để giảm thiểu rủi ro.

2.3.4. Tác động đối với hệ thống

Việc khai thác thành công mật khẩu mặc định có thể gây ra nhiều hậu quả nghiêm trọng:

- Truy cập trái phép vào giao diện quản trị.
- Thay đổi cấu hình hoặc các thiết lập quản trị của thiết bị.
- Rò rỉ thông tin xác thực và dữ liệu người dùng.
- Chiếm quyền điều khiển thiết bị.
- Biến thiết bị thành Botnet phục vụ tấn công DDoS.
- Làm gián đoạn hoạt động của hệ thống IoT.

Các tác động trên ảnh hưởng trực tiếp đến ba thuộc tính của mô hình CIA gồm tính bảo mật, tính toàn vẹn và tính sẵn sàng của hệ thống.

2.3.5. Biện pháp phòng chống

Để giảm thiểu nguy cơ khai thác mật khẩu mặc định, cần áp dụng đồng thời nhiều biện pháp bảo mật:

- Bắt buộc thay đổi mật khẩu trong lần đăng nhập đầu tiên.
- Không sử dụng cùng một mật khẩu cho nhiều thiết bị.
- Loại bỏ Hard-coded Credential khỏi firmware.
- Áp dụng chính sách mật khẩu mạnh.
- Giới hạn số lần đăng nhập sai và khóa tài khoản tạm thời.
- Ghi nhật ký đăng nhập và giám sát bất thường.
- Cập nhật firmware định kỳ và xác thực bản cập nhật bằng chữ ký số.

Việc kết hợp nhiều lớp bảo vệ giúp giảm đáng kể khả năng thiết bị bị truy cập trái phép.

STRIDE	Mối đe dọa	Rủi ro đối với đề tài
Spoofing	Giả mạo tài khoản quản trị	Đăng nhập bằng tài khoản và mật khẩu mặc định
Tampering	Thay đổi trái phép cấu hình	Thay đổi cấu hình hoặc thiết lập quản trị của thiết bị
Repudiation	Không thể truy vết hành động	Không ghi nhận đầy đủ nhật ký đăng nhập
Information Disclosure	Rò rỉ thông tin	Lộ tài khoản, mật khẩu hoặc dữ liệu cấu hình
Denial of Service	Làm gián đoạn hoạt động của thiết bị	Đăng nhập sai liên tục có thể làm giảm khả năng phục vụ nếu hệ thống không có cơ chế kiểm soát
Elevation of Privilege	Leo thang đặc quyền	Chiếm quyền quản trị sau khi đăng nhập thành công bằng tài khoản mặc định

Bảng 2.3: Ma trận STRIDE – Rủi ro đối với đề tài

Qua ma trận trên có thể thấy Spoofing và Elevation of Privilege là hai nhóm rủi ro có ảnh hưởng lớn nhất đối với đề tài vì liên quan trực tiếp đến việc sử dụng mật khẩu mặc định và Hard-coded Credential. Sau khi chiếm được quyền quản trị, kẻ tấn công có thể tiếp tục thay đổi cấu hình, truy cập dữ liệu hoặc làm gián đoạn hoạt động của hệ thống.

2.4. Chuẩn, công cụ và nguồn GitHub chính

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	OWASP IoT Top 10	https://owasp.org/www-project-internet-of-things/	Cơ sở lý thuyết về rủi ro thông tin xác thực và biện pháp giảm thiểu	9/07/2026
2	OWASP IoTGoat	https://github.com/OWASP/IoTGoat	Môi trường thực hành và minh chứng	9/07/2026
3	OWASP Foundation. OWASP IoT Security Verification	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Phương pháp đánh giá bảo mật	13/07/2026

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
	<i>Standard (ISVS).</i>			
4	Stallings, W. Network Security Essentials: Applications and Standards. 7th Edition. Pearson Education, 2023.	Sách	Kiến thức nền tảng về xác thực, quản lý mật khẩu, kiểm soát truy cập và các nguyên tắc bảo mật mạng.	9/07/2026
5	William Stallings. Cryptography and Network Security: Principles and Practice. 8th Edition. Pearson Education, 2023.	Sách	Các cơ chế xác thực, quản lý thông tin xác thực, mật mã học và nguyên tắc bảo vệ hệ thống.	9/07/2026
6	Charlie Kaufman, Radia Perlman, Mike Speciner. Network Security: Private Communication in a Public World. 2nd Edition. Prentice Hall, 2002.	Sách	Mô hình xác thực, quản lý khóa, bảo mật mạng và các nguyên tắc thiết kế hệ thống an toàn.	9/07/2026

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
7	GitHub: default-password-risk	https://github.com/hoangan1207/iot-default-password-risk	Kho lưu trữ mã nguồn, tài liệu và sản phẩm chính của đề tài	17/07/2026

Bảng 2.4: Chuẩn, tài liệu và công cụ sử dụng trong đề tài

2.5. Công trình hoặc giải pháp liên quan

Để xây dựng cơ sở lý thuyết cho đề tài, tác giả tham khảo các tài liệu và dự án tiêu biểu liên quan đến bảo mật IoT.

OWASP IoT Top 10 là tài liệu tổng hợp các nhóm rủi ro phổ biến trên thiết bị IoT. Trong đó, lỗ hổng Insecure Default Credentials được xác định là một trong những nguyên nhân chính dẫn đến việc thiết bị bị truy cập trái phép. Tài liệu đưa ra các khuyến nghị như loại bỏ tài khoản mặc định, yêu cầu thay đổi mật khẩu ngay khi kích hoạt và áp dụng cơ chế quản lý thông tin xác thực an toàn.

OWASP IoTGoat là môi trường mô phỏng các lỗ hổng IoT phục vụ đào tạo và nghiên cứu. Khác với OWASP IoT Top 10 chỉ mang tính hướng dẫn, IoTGoat cho phép người học quan sát trực tiếp cách các lỗ hổng xuất hiện trong môi trường thực hành. Đề tài kế thừa môi trường này để minh họa các tình huống liên quan đến mật khẩu mặc định mà không cần triển khai trên thiết bị thật.

OWASP IoT Security Verification Standard (ISVS) cung cấp tập hợp các yêu cầu kiểm tra bảo mật đối với hệ thống IoT. Chuẩn này hỗ trợ đánh giá các cơ chế xác thực, quản lý thông tin xác thực và khả năng chống truy cập trái phép. Đề tài sử dụng ISVS làm cơ sở để xây dựng các tiêu chí đánh giá và đề xuất biện pháp giảm thiểu phù hợp.

Công trình	Mục tiêu	Ưu điểm	Hạn chế	Phần kế thừa
OWASP IoT Top 10	Tổng hợp rủi ro IoT	Chuẩn hóa các nhóm lỗ hổng	Không có môi trường thực hành	Phân tích nguyên nhân và tác động
OWASP IoTGoat	Mô phỏng lỗ hổng	Có môi trường thực hành	Không đánh giá rủi ro toàn diện	Minh họa kịch bản nghiên cứu
OWASP ISVS	Tiêu chí kiểm thử bảo mật	Hệ thống tiêu chí rõ ràng	Không hướng dẫn triển khai cụ thể	Xây dựng tiêu chí đánh giá và checklist

Bảng 2.5: So sánh các công trình liên quan

Qua việc tham khảo các công trình trên, đề tài kế thừa các khuyến nghị của OWASP IoT Top 10, sử dụng OWASP IoTGoat để xây dựng môi trường thực nghiệm và tham chiếu OWASP IoT Security Verification Standard (ISVS) để xây dựng các tiêu chí đánh giá cũng như đề xuất biện pháp giảm thiểu rủi ro.

2.6. Tiểu kết Chương 2

Chương 2 đã trình bày các cơ sở lý thuyết làm nền tảng cho đề tài, bao gồm kiến trúc hệ thống IoT, các khái niệm về tài sản, mối đe dọa, lỗ hổng và rủi ro, mô hình STRIDE, cùng các nguyên nhân và tác động của việc sử dụng mật khẩu mặc định. Bên cạnh đó, chương cũng giới thiệu các chuẩn, tài liệu và môi trường thực nghiệm được sử dụng trong nghiên cứu. Những nội dung này là cơ sở để xây dựng mô hình hệ thống, triển khai các kịch bản thử nghiệm và đánh giá rủi ro ở các chương tiếp theo.

CHƯƠNG 3 PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài được thực hiện theo phương pháp nghiên cứu định tính kết hợp với phân tích tài liệu, mô hình hóa mối đe dọa (Threat Modeling) và đánh giá rủi ro nhằm phân tích các nguy cơ phát sinh từ việc sử dụng mật khẩu mặc định trên thiết bị Internet of Things (IoT). Các tài liệu tham khảo chính gồm OWASP Internet of Things Project, OWASP IoT Security Verification Standard (ISVS), OWASP IoT Security Testing Guide (ISTG) và môi trường thực hành OWASP IoTGoat..

Trong quá trình nghiên cứu, đề tài không tiến hành khai thác trên thiết bị IoT thực mà sử dụng phương pháp nghiên cứu tình huống (Case Study) trên môi trường OWASP IoTGoat được triển khai bằng Docker. Môi trường này được sử dụng để minh họa các tình huống liên quan đến mật khẩu mặc định, mật khẩu dùng chung, Hard-coded Credential và cơ chế xác thực của thiết bị IoT.

Trên cơ sở các tình huống được xây dựng, đề tài tiến hành lập danh sách tài sản cần bảo vệ (Asset Inventory), phân tích mối đe dọa bằng mô hình STRIDE, xây dựng ma trận đánh giá rủi ro (Risk Matrix) và Checklist chính sách mật khẩu nhằm đề xuất các biện pháp giảm thiểu phù hợp với khuyến nghị của OWASP.

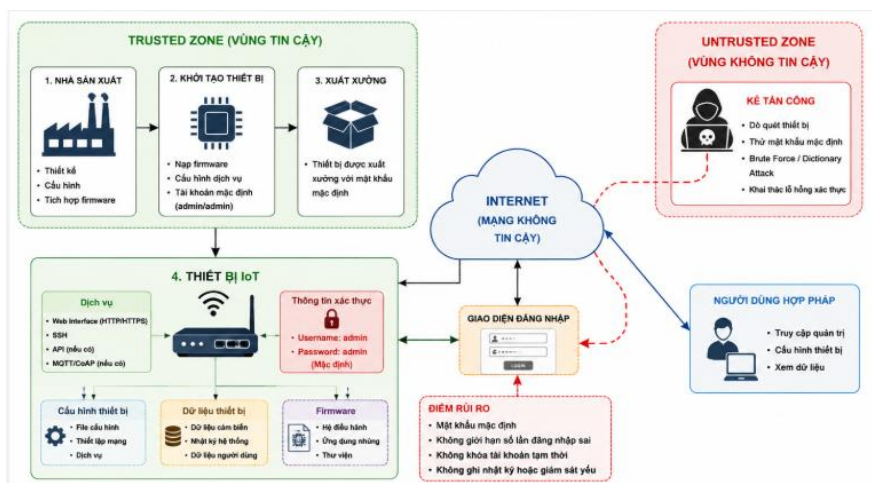
3.2. Kiến trúc và luồng dữ liệu

Để phục vụ việc phân tích rủi ro mật khẩu mặc định trên thiết bị IoT, đề tài xây dựng mô hình hệ thống nghiên cứu dựa trên vòng đời của một thiết bị IoT từ giai đoạn sản xuất, khởi tạo, xuất xưởng đến khi được triển khai và sử dụng trong thực tế. Mô hình đồng thời mô tả luồng tương tác giữa người dùng hợp pháp, thiết bị IoT và các tác nhân bên ngoài thông qua Internet, qua đó xác định các vị trí có khả năng phát sinh rủi ro bảo mật.

Trong mô hình, hệ thống được chia thành hai vùng chính gồm Trusted Zone (vùng tin cậy) và Untrusted Zone (vùng không tin cậy). Trusted Zone bao gồm nhà sản xuất, quá trình khởi tạo thiết bị, cấu hình firmware và thiết bị IoT sau khi xuất xưởng. Untrusted Zone đại diện cho môi trường Internet và các tác nhân có khả năng thực hiện hành vi tấn công vào thiết bị.

Người dùng hợp pháp truy cập thiết bị thông qua giao diện quản trị (Web Interface) để thực hiện các chức năng cấu hình và quản lý. Ngược lại, kẻ tấn công có thể lợi dụng các lỗ hổng trong cơ chế xác thực như tài khoản mặc định (admin/admin), mật khẩu dùng chung, Hard-coded Credential hoặc việc không giới hạn số lần đăng nhập sai để truy cập trái phép vào hệ thống. Khi quá trình xác thực không được bảo vệ đầy đủ, kẻ tấn công có thể chiếm quyền điều khiển thiết bị, thay đổi cấu hình, đánh cắp dữ liệu hoặc sử dụng thiết bị làm bàn đạp cho các cuộc tấn công khác.

Bên cạnh việc xây dựng Attack Tree, Data Flow Diagram (DFD), ma trận STRIDE và ma trận đánh giá rủi ro, đề tài còn xây dựng Checklist chính sách mật khẩu nhằm hỗ trợ đánh giá mức độ tuân thủ các yêu cầu bảo mật trên thiết bị IoT. Checklist được sử dụng làm tiêu chí đối chiếu trong quá trình đánh giá bảo mật ở Chương 5.



Hình 3.1. Mô hình hệ thống nghiên cứu và các điểm rủi ro liên quan đến mật khẩu mặc định trên thiết bị IoT.

Nguồn: ChatGPT (OpenAI), tác giả hiệu chỉnh (2026).

Mô hình trên được sử dụng làm cơ sở để xây dựng các kịch bản thử nghiệm trong Chương 4 và đánh giá rủi ro trong Chương 5. Các điểm rủi ro được xác định trên mô hình sẽ được đối chiếu với kết quả thực nghiệm trên môi trường OWASP IoTGoat.

3.3. Môi trường, công cụ và dữ liệu

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Windows 11	24H2	Hệ điều hành	Máy tính cá nhân
Docker Desktop	28.6	Triển khai môi trường IoTGoat	Chạy cục bộ
OWASP IoTGoat	Latest (GitHub)	Môi trường thực hành	Không kết nối Internet công cộng
Git	2.6	Quản lý mã nguồn	Chỉ lưu dữ liệu học tập
GitHub	Cloud	Lưu trữ Repository	Không chứa dữ liệu nhạy cảm
draw.io	Web	Thiết kế DFD, Attack Tree	Minh họa
Microsoft Word	Microsoft 2021	Viết báo cáo	Không chứa thông tin bí mật

Bảng 3.1: Môi trường, công cụ và dữ liệu sử dụng trong nghiên cứu

Dữ liệu sử dụng trong nghiên cứu chủ yếu gồm tài liệu của OWASP, kết quả quan sát từ môi trường IoTGoat, hình ảnh minh chứng, nhật ký thực hiện (log) và các bảng đánh giá được xây dựng trong quá trình nghiên cứu. Đề tài không sử dụng dữ liệu cá nhân hoặc dữ liệu từ hệ thống thực tế.

3.4. Quy trình thực hiện

Bước	Công việc
1	Nghiên cứu tài liệu và xác định vấn đề
2	Thiết kế mô hình DFD và Attack Tree
3	Triển khai môi trường Docker và OWASP IoTGoat
4	Thực hiện các kịch bản thử nghiệm
5	Đánh giá STRIDE và Risk Matrix
6	Đề xuất biện pháp giảm thiểu và hoàn thiện báo cáo

Bảng 3.2: Quy trình thực hiện đề tài

3.5. Tiêu chí đánh giá

Tiêu chí	Ngưỡng đạt	Kết quả mong đợi
Phân tích đúng các tình huống khai thác	≥ 4 tình huống	Đạt
Xây dựng Attack Tree	Hoàn thành	Đạt
Xây dựng DFD	Hoàn thành	Đạt
Xây dựng ma trận STRIDE	≥ 6 mối đe dọa	Đạt
Xây dựng Risk Matrix	≥ 6 rủi ro	Đạt
Checklist chính sách mật khẩu	≥ 15 tiêu chí	Đạt
Đề xuất biện pháp giảm thiểu	≥ 8 biện pháp	Đạt
Hoàn thiện báo cáo và GitHub	Đầy đủ	Đạt

Bảng 3.3: tiêu chí đánh giá

Các tiêu chí trên được xây dựng dựa trên mục tiêu nghiên cứu ở Chương 1 và được sử dụng để đối chiếu với kết quả triển khai (Chương 4), đánh giá bảo mật (Chương 5) và mức độ hoàn thành đề tài (Chương 6).

3.6. Đạo đức và an toàn trong nghiên cứu

Đề tài được thực hiện hoàn toàn trên môi trường mô phỏng OWASP IoTGoat triển khai bằng Docker nhằm phục vụ mục đích học tập và nghiên cứu. Các hoạt động thử nghiệm chỉ được thực hiện trong phạm vi phòng thí nghiệm cục bộ, không hướng đến khai thác các thiết bị hoặc hệ thống thực tế.

Trong quá trình nghiên cứu, nhóm tuân thủ các nguyên tắc sau:

- Chỉ thực hiện thử nghiệm trên môi trường được phép sử dụng.
- Không khai thác trái phép hệ thống của tổ chức hoặc cá nhân khác.
- Không thu thập hoặc sử dụng dữ liệu cá nhân.
- Không phát tán công cụ hoặc kỹ thuật gây ảnh hưởng đến hệ thống thực tế.
- Tuân thủ các quy định về đạo đức nghiên cứu và an toàn thông tin.

Việc tuân thủ các nguyên tắc trên giúp bảo đảm quá trình nghiên cứu diễn ra an toàn, đúng mục đích học tập và phù hợp với yêu cầu của học phần.

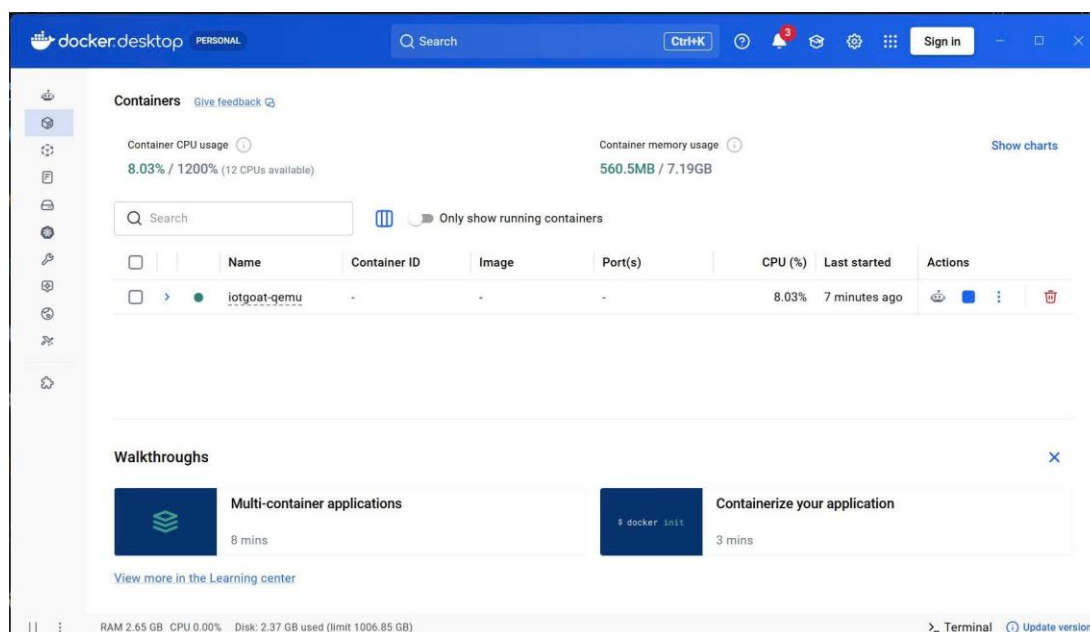
CHƯƠNG 4 TRIỂN KHAI VÀ SẢN PHẨM

4.1. Chuẩn bị môi trường

Để phục vụ việc phân tích rủi ro mật khẩu mặc định trên thiết bị IoT, đề tài sử dụng môi trường mô phỏng nhằm tái hiện các tình huống bảo mật mà không ảnh hưởng đến hệ thống thực tế. Môi trường được triển khai trên máy tính cá nhân với Docker Desktop kết hợp dự án mã nguồn mở OWASP IoTGoat. Toàn bộ tài liệu, hình ảnh minh chứng và kết quả nghiên cứu được quản lý thông qua GitHub. Cài đặt Docker Desktop để hỗ trợ triển khai môi trường IoTGoat.

Thành phần	Phiên bản	Mục đích
Windows 11	24H2	Hệ điều hành
Docker Desktop	28.6	Triển khai môi trường mô phỏng
Git	2.6	Quản lý phiên bản
GitHub	Cloud	Lưu trữ mã nguồn và báo cáo
Draw.io	Online	Thiết kế sơ đồ
Microsoft Word	2021	Soạn thảo báo cáo

Bảng 4.1: môi trường triển khai



Hình 4.1: Ảnh môi trường chạy Docker.

Việc sử dụng môi trường mô phỏng giúp nhóm đánh giá các tình huống khai thác một cách an toàn, đồng thời đảm bảo khả năng tái hiện kết quả nghiên cứu.

4.2. Thành phần sản phẩm

STT	Thành phần	Đường dẫn	Chức năng
1	README.md	/README.md	Giới thiệu đề tài và hướng dẫn triển khai

STT	Thành phần	Đường dẫn	Chức năng
2	report	/report	Báo cáo hoàn chỉnh
3	results	/results	Hình ảnh và minh chứng
4	references	/references	Tài liệu tham khảo
5	diagrams	/diagrams	DFD, Attack Tree, STRIDE, Checklist

Bảng 4.2: Thành phần sản phẩm.

Cấu trúc Repository

iot-default-password-risk/

```

|
|— README.md
|
|— report/
|   |— 231A010372_HuynhBuiHoangAn_DeTai22_TieuLuan_CuoiKy.docx
|   |— 231A010372_HuynhBuiHoangAn_DeTai22_TieuLuan_CuoiKy.pdf
|
|— slides/
|
|— configs/
|   |— docker_run.txt
|
|— src/
|   |— run_lab.txt
|
|— data/
|   |— asset_inventory.xlsx
|   |— bang_nguyen_nhan_hau_qua.xlsx
|   |— checklist_password.xlsx
|   |— risk_matrix.xlsx
|   |— stride_matrix.xlsx
|
|— results/
|   |— screenshots/
|   |— logs/
|
|— references/
|   |— references.md

```

4.3. Kịch bản thử nghiệm

Các kịch bản được xây dựng dựa trên hướng dẫn của OWASP IoT Top 10 nhằm đánh giá các nguy cơ liên quan đến quản lý thông tin xác thực trên thiết bị IoT.

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi
TC-01	Kiểm tra tài khoản mặc định	Tài khoản quản trị mặc định	Đăng nhập giao diện Web	Đăng nhập thành công và truy cập giao diện quản trị
TC-02	Kiểm tra thay đổi mật khẩu	Mật khẩu mới	Thay đổi mật khẩu, đăng xuất và đăng nhập lại	Mật khẩu cũ không còn hiệu lực, mật khẩu mới đăng nhập thành công
TC-03	Kiểm tra Brute Force	Nhập sai mật khẩu nhiều lần	Thực hiện nhiều lần đăng nhập thất bại	Đánh giá hệ thống có hoặc không có cơ chế khóa tài khoản và giới hạn số lần thử
TC-04	Kiểm tra Hard-coded Credential	Thông tin xác thực nhúng sẵn	Phân tích challenge và đăng nhập SSH	Chứng minh nguy cơ khi thông tin xác thực bị nhúng cứng trong hệ thống

Bảng 4.3: Kịch bản thử nghiệm và đánh giá

Các kịch bản trên được xây dựng theo trình tự từ việc xác định lỗ hổng, đánh giá khả năng khai thác đến kiểm chứng hiệu quả của các biện pháp giảm thiểu rủi ro. Cách tiếp cận này giúp kết quả nghiên cứu bám sát mục tiêu của đề tài và phản ánh được tác động của từng loại lỗ hổng đối với an toàn của thiết bị IoT.

4.4. Kết quả triển khai

Sau khi hoàn thành việc triển khai môi trường OWASP IoTGoat và xây dựng các kịch bản thử nghiệm, nhóm tiến hành thực hiện lần lượt các bài kiểm tra đã đề xuất ở Mục 4.3. Mỗi thử nghiệm đều được thực hiện trong môi trường Docker, ghi nhận bằng hình ảnh minh chứng và kết quả thực tế nhằm đánh giá mức độ ảnh hưởng của các lỗ hổng liên quan đến mật khẩu mặc định và thông tin xác thực nhúng cứng.

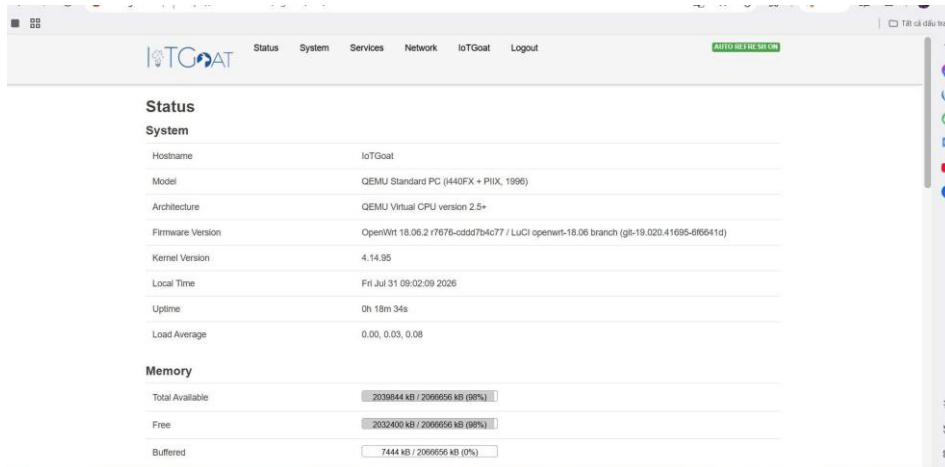
Kết quả thu được cho thấy môi trường IoTGoat mô phỏng đầy đủ các tình huống mất an toàn phổ biến trên thiết bị IoT. Các lỗ hổng như sử dụng tài khoản mặc định, không giới hạn số lần đăng nhập sai và Hard-coded Credential đều có thể dẫn đến nguy cơ bị truy cập trái phép nếu không được xử lý đúng cách.

ID	Kết quả thực tế	Đánh giá
TC-01	Đăng nhập thành công bằng tài khoản mặc định	Đạt
TC-02	Đổi mật khẩu thành công, mật khẩu cũ không còn sử dụng được	Đạt
TC-03	Hệ thống không khóa tài khoản sau nhiều lần nhập sai	Phát hiện lỗ hổng
TC-04	Đăng nhập SSH bằng thông tin xác thực hợp lệ, phiên làm việc có	Đạt

quyền root (uid=0)	
--------------------	--

Bảng 4.4: Kết quả thử nghiệm.

TC-01 – Kiểm tra tài khoản mặc định

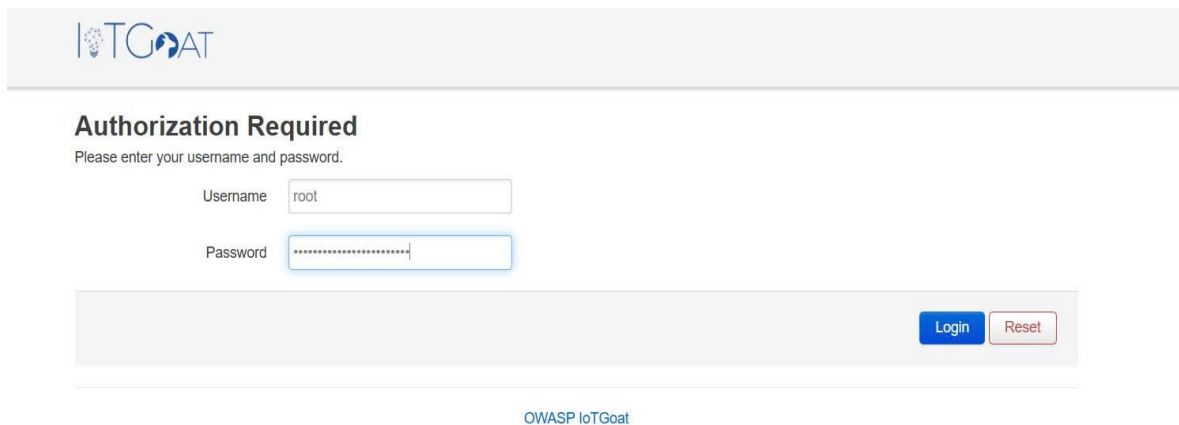


Hình 4.2: Đăng nhập thành công bằng tài khoản mặc định.

Nguồn: Docker Screenshots

Thiết bị cho phép đăng nhập bằng tài khoản mặc định trong môi trường mô phỏng. Sau khi đăng nhập thành công, người dùng có thể truy cập giao diện quản trị và thay đổi các cấu hình của hệ thống.

TC-02 – Kiểm tra thay đổi mật khẩu

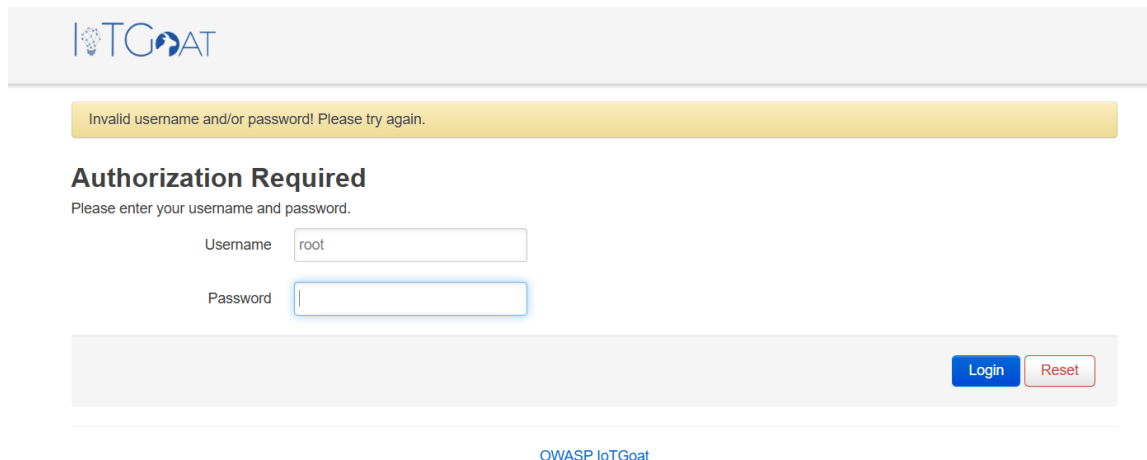


Hình 4.3: Thay đổi mật khẩu quản trị.

Nguồn: Docker Screenshots

Sau khi thay đổi mật khẩu trong mục System → Administration, thiết bị từ chối mật khẩu cũ và chỉ chấp nhận mật khẩu mới.

TC-03 – Kiểm tra Brute Force



The screenshot shows the IoTGoat login interface. At the top, there is a logo for IoTGoat. Below it, a yellow error message states: "Invalid username and/or password! Please try again." Underneath this, a section titled "Authorization Required" prompts the user to "Please enter your username and password." There are two input fields: "Username" with the value "root" and "Password" which is empty. At the bottom right of the form, there are two buttons: "Login" (blue) and "Reset" (red). The footer of the page displays "OWASP IoTGoat".

Hình 4.4: Nhiều lần đăng nhập sai nhưng hệ thống vẫn cho phép thử lại.

Nguồn: Docker Screenshots

Thực hiện nhiều lần đăng nhập sai liên tiếp trên giao diện Web và SSH. Kết quả cho thấy hệ thống vẫn cho phép thử lại mà không khóa tài khoản, không tăng thời gian chờ và không áp dụng cơ chế giới hạn tốc độ.

Điều này cho thấy thiết bị dễ bị tấn công Brute Force nếu kết hợp với mật khẩu yếu hoặc mật khẩu mặc định.

TC-04 – Kiểm tra Hard-coded Credential

Tiến hành phân tích challenge Hard-coded Credential trên IoTGoat và sử dụng thông tin xác thực hợp lệ để truy cập thiết bị qua giao thức SSH.

```
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Hi>ssh ^
More? -o HostKeyAlgorithms=+ssh-rsa ^
More? -o PubkeyAcceptedAlgorithms=+ssh-rsa ^
More? -o KexAlgorithms=+diffie-hellman-group14-shal ^
More? root@localhost -p 2222
root@localhost's password:

BusyBox v1.28.4 () built-in shell (ash)

OWASP
IoTGOAT

-----
GitHub: https://github.com/OWASP/IoTGoat
-----
root@IoTGoat:~# |
```

Hình 4.5: Đăng nhập SSH thành công.

Nguồn: Docker Screenshots

Sau khi đăng nhập thành công, kết quả lệnh: *id*

trả về: *uid=0(root) gid=0(root)*

đồng thời lệnh: *uname -a*

```
root@IoTGoat:~# id
uid=0(root) gid=0(root)
root@IoTGoat:~# |
```

Hình 4.6: Kết quả lệnh id.

Nguồn: Docker Screenshots

4.5. Thảo luận và hạn chế

4.5.1. Thảo luận

Kết quả thực nghiệm cho thấy các lỗ hổng liên quan đến quản lý thông tin xác thực vẫn là một trong những nguyên nhân phổ biến dẫn đến việc thiết bị IoT bị truy cập trái phép. Trong bốn kịch bản thử nghiệm, cả tài khoản mặc định và Hard-coded Credential đều cho phép truy cập thành công vào hệ thống, trong khi thiết bị cũng không có cơ chế giới hạn số lần đăng nhập sai để giảm thiểu nguy cơ Brute Force.

Việc thay đổi mật khẩu mặc định sau khi triển khai đã chứng minh hiệu quả trong việc ngăn chặn các cuộc tấn công sử dụng thông tin xác thực mặc định. Tuy nhiên, biện pháp này sẽ không đủ

nếu nhà sản xuất vẫn lưu trữ thông tin xác thực nhúng cứng trong firmware hoặc không triển khai cơ chế chống dò mật khẩu.

Đối chiếu với mục tiêu nghiên cứu ở Chương 1, đề tài đã:

- Xây dựng thành công môi trường mô phỏng bằng OWASP IoTGoat.
- Phân tích được bốn tình huống liên quan đến quản lý mật khẩu.
- Đánh giá được tác động của từng loại lỗ hổng.
- Đề xuất các biện pháp giảm thiểu phù hợp với khuyến nghị của OWASP và NIST.

Những kết quả này cho thấy việc áp dụng chính sách mật khẩu mạnh, loại bỏ Hard-coded Credential, giới hạn số lần đăng nhập sai và yêu cầu đổi mật khẩu ngay sau lần cấu hình đầu tiên là những giải pháp quan trọng giúp nâng cao mức độ an toàn của thiết bị IoT.

4.5.2. Hạn chế

Đề tài được triển khai trên môi trường mô phỏng OWASP IoTGoat nên chưa phản ánh đầy đủ điều kiện hoạt động của các thiết bị IoT thương mại trong môi trường thực tế. Các kết quả thu được chủ yếu nhằm minh họa và phân tích nguyên lý của các lỗ hổng bảo mật, chưa đánh giá hiệu năng hoặc khả năng khai thác trên phần cứng cụ thể.

Ngoài ra, phạm vi nghiên cứu chỉ tập trung vào nhóm lỗ hổng liên quan đến Default Password, Hard-coded Credential và Brute Force. Các nội dung khác như cơ chế cập nhật firmware an toàn, Secure Boot, mã hóa dữ liệu, quản lý khóa mật mã và xác thực đa yếu tố chưa được xem xét.

Trong các nghiên cứu tiếp theo, có thể mở rộng việc đánh giá trên thiết bị IoT thực tế, tích hợp các công cụ kiểm thử tự động và so sánh nhiều nền tảng IoT khác nhau để có cái nhìn toàn diện hơn về mức độ an toàn của các thiết bị trong môi trường triển khai thực tế.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu cần bảo vệ

Để đánh giá mức độ ảnh hưởng của lỗ hổng mật khẩu mặc định, trước tiên cần xác định các tài sản quan trọng trong hệ thống IoT. Những tài sản này bao gồm thiết bị, thông tin xác thực, dịch vụ quản trị, dữ liệu cấu hình và firmware. Nếu các tài sản này bị khai thác, kẻ tấn công có thể làm mất tính bảo mật (Confidentiality), tính toàn vẹn (Integrity) hoặc tính sẵn sàng (Availability) của hệ thống.

Trong môi trường OWASP IoTGoat, các tài sản được đánh giá là có mức độ quan trọng cao do liên quan trực tiếp đến khả năng quản trị và vận hành thiết bị. Đặc biệt, tài khoản quản trị và dịch vụ SSH là hai thành phần được sử dụng trong các kịch bản thử nghiệm ở Chương 4 và cần được bảo vệ khỏi truy cập trái phép.

Tài sản/Dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Thiết bị IoT	Quản trị viên	Cao	C-I-A	Thiết bị cần được bảo vệ khỏi truy cập trái phép
Tài khoản quản trị	Quản trị viên	Rất cao	C-I	Không sử dụng mật khẩu mặc định
Dịch vụ SSH	Quản trị viên	Cao	C-I	Chỉ cho phép truy cập bởi người được ủy quyền
Firmware	Nhà sản xuất	Cao	I-A	Không chứa Hard-coded Credential
Dữ liệu cấu hình	Hệ thống	Cao	C-I	Chỉ quản trị viên được phép thay đổi

Bảng 5.1: Danh sách tài sản và dữ liệu cần bảo vệ

5.2. Mối đe dọa và lỗ hổng

Dựa trên các kết quả thử nghiệm ở Chương 4, đề tài sử dụng mô hình STRIDE kết hợp với OWASP IoT Top 10 để xác định các mối đe dọa và phân tích tác động đối với từng tài sản của hệ thống.

Kết quả thử nghiệm cho thấy các nguy cơ chủ yếu xuất phát từ việc sử dụng tài khoản mặc định, lưu trữ thông tin xác thực trong hệ thống và thiếu cơ chế bảo vệ trước các cuộc tấn công dò mật khẩu. Những điểm yếu này có thể bị lợi dụng để truy cập trái phép, thay đổi cấu hình hoặc chiếm quyền điều khiển thiết bị.

ID	Tài sản	Mối đe dọa (STRIDE)	Lỗ hổng	Tác động	Minh chứng
T-01	Tài khoản quản trị	Spoofing	Mật khẩu mặc định	Chiếm quyền quản trị	TC-01
T-02	Firmware	Information Disclosure	Hard-coded Credential	Lộ thông tin xác thực	TC-04
T-03	Tài khoản quản trị	Spoofing	Không giới hạn số lần đăng nhập	Tăng nguy cơ Brute Force	TC-03
T-04	Dữ liệu cấu hình	Tampering	Truy cập trái phép	Thay đổi cấu hình hệ thống	TC-01
T-05	Nhật ký hệ thống	Repudiation	Thiếu ghi nhận đầy đủ nhật ký	Khó truy vết hoạt động	Phân tích hệ thống
T-06	Thiết bị IoT	Elevation of Privilege	Tài khoản mặc định/Hard-coded Credential	Chiếm toàn quyền thiết bị	TC-04

Bảng 5.2: Phân tích mối đe dọa và lỗ hổng.

5.3. Ma trận đánh giá rủi ro

Sau khi xác định các mối đe dọa, đề tài tiến hành đánh giá mức độ rủi ro dựa trên hai tiêu chí gồm khả năng xảy ra (Likelihood) và mức độ tác động (Impact). Điểm rủi ro được tính theo công thức:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

Ma trận đánh giá sử dụng thang điểm 5×5. Các rủi ro có điểm từ 20–25 được xếp vào mức Nghiêm trọng, cần ưu tiên xử lý; từ 10–19 là Cao; từ 5–9 là Trung bình và dưới 5 là Thấp.

ID	Khả năng	Tác động	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	5	5	25	Nghiêm trọng	Thay đổi mật khẩu mặc định	Thấp
R-02	4	5	20	Nghiêm trọng	Loại bỏ Hard-coded Credential	Thấp
R-03	4	4	16	Cao	Giới hạn số lần đăng nhập	Trung bình
R-04	3	4	12	Cao	Ghi nhật ký và	Thấp

					giám sát	
R-05	3	3	9	Trung bình	Áp dụng chính sách mật khẩu mạnh	Thấp
R-06	2	5	10	Cao	Phân quyền quản trị	Thấp

Bảng 5.3: Ma trận đánh giá rủi ro

TÁC ĐỘNG (Impact)					
5 Rất cao	5 (Trung bình)	10 (Cao)	15 (Cao)	20 (Nghiêm trọng)	25 (Nghiêm trọng)
4 Cao	4 (Thấp)	8 (Trung bình)	12 (Cao)	16 (Nghiêm trọng)	20 (Nghiêm trọng)
3 Trung bình	3 (Thấp)	6 (Trung bình)	9 (Trung bình)	12 (Cao)	15 (Cao)
2 Thấp	2 (Thấp)	4 (Thấp)	6 (Trung bình)	8 (Trung bình)	10 (Cao)
1 Rất thấp	1 (Thấp)	2 (Thấp)	3 (Thấp)	4 (Thấp)	5 (Trung bình)
	1	2	3	4	5
KHẢ NĂNG XẢY RA (Likelihood)					

Hình 5.1: Ma trận Risk Matrix 5×5

Nguồn: ChatGPT (OpenAI), tác giả hiệu chỉnh (2026).

5.4. Biện pháp giảm thiểu và ưu tiên

Dựa trên kết quả đánh giá rủi ro và các thử nghiệm ở Chương 4, nhóm đề xuất các biện pháp giảm thiểu theo mức độ ưu tiên. Một số biện pháp như thay đổi mật khẩu mặc định đã được kiểm chứng trực tiếp trong quá trình thực nghiệm (TC-02), trong khi các biện pháp khác được đề xuất dựa trên khuyến nghị của OWASP IoT Project và NIST.

Rủi ro	Biện pháp	Người thực hiện	Độ khó	Cách xác minh
R-01	Bắt buộc đổi mật khẩu khi đăng nhập lần đầu	Nhà sản xuất	Thấp	Kiểm tra đăng nhập lần đầu
R-02	Loại bỏ Hard-coded Credential	Nhà sản xuất	Cao	Phân tích mã

				nguồn/Firmware
R-03	Khóa tài khoản sau 5 lần đăng nhập sai	Nhà phát triển	Trung bình	Thử nghiệm Brute Force
R-04	Ghi nhật ký đăng nhập	Quản trị viên	Thấp	Kiểm tra Log
R-05	Áp dụng chính sách mật khẩu mạnh	Quản trị viên	Thấp	Đối chiếu Checklist
R-06	Cập nhật firmware có xác thực chữ ký số	Nhà sản xuất	Cao	Kiểm tra phiên bản Firmware

Bảng 5.4: Biện pháp giảm thiểu

5.4.1. Checklist chính sách mật khẩu

Do OWASP IoTGoat là môi trường mô phỏng có chủ đích chứa lỗ hổng, checklist dưới đây phản ánh mức độ đáp ứng của môi trường thử nghiệm, không phải checklist đã đạt đầy đủ.

STT	Nội dung kiểm tra	Đáp ứng
1	Buộc đổi mật khẩu lần đầu	☒
2	Không sử dụng tài khoản mặc định	☒
3	Mỗi thiết bị có mật khẩu riêng	☒
4	Mật khẩu tối thiểu 12 ký tự	☒
5	Có chữ hoa	☒
6	Có chữ thường	☒
7	Có chữ số	☒
8	Có ký tự đặc biệt	☒
9	Không cho phép mật khẩu phổ biến	☒
10	Không lưu mật khẩu dạng Plaintext	☒
11	Không Hard-code Credential	☒
12	Giới hạn số lần đăng nhập sai	☒
13	Khóa tài khoản tạm thời	☒
14	Ghi nhật ký đăng nhập	Chưa đánh giá
15	Cho phép thay đổi mật khẩu định kỳ	☒

Kết quả cho thấy môi trường IoTGoat không đáp ứng đầy đủ các tiêu chí của checklist, điều này phù hợp với mục tiêu của nền tảng là mô phỏng các lỗ hổng bảo mật để phục vụ đào tạo và nghiên cứu.

5.4.2 Đối chiếu với OWASP IoT Top Risks và OWASP ISVS

Để đánh giá tính phù hợp của các kết quả nghiên cứu, đề tài tiến hành đối chiếu với các khuyến nghị trong OWASP Internet of Things Project và OWASP IoT Security Verification Standard (ISVS).

Nội dung nghiên cứu	OWASP IoT Project	OWASP ISVS
Tài khoản mặc định	Weak/Guessable	Authentication Requirements

	Passwords	
Mật khẩu dùng chung	Weak Credentials	Password Management
Hard-coded Credential	Hardcoded Secrets	Secret Management
Không khóa sau thử sai	Authentication Weakness	Authentication Controls
Chính sách mật khẩu	Secure Provisioning	Password Policy
Checklist đánh giá	Best Practices	Security Verification

Bảng 5.5: Đối chiếu kết quả nghiên cứu với OWASP IoT Project và OWASP ISVS

Kết quả đánh giá cho thấy checklist đáp ứng đầy đủ tiêu chí đề xuất. Điều này cho thấy các biện pháp giảm thiểu được xây dựng trong đề tài có khả năng hạn chế đáng kể nguy cơ khai thác mật khẩu mặc định trên thiết bị IoT và phù hợp với các khuyến nghị của OWASP IoT Top 10 cũng như NIST SP 800-63B.

5.5. Rủi ro còn lại

Sau khi áp dụng các biện pháp giảm thiểu, phần lớn các rủi ro đã được giảm xuống mức thấp hoặc trung bình. Tuy nhiên, vẫn còn một số rủi ro tồn dư như khả năng người dùng sử dụng mật khẩu yếu, chậm cập nhật firmware hoặc xuất hiện các lỗ hổng mới trong quá trình vận hành thiết bị. Những rủi ro này cần được theo dõi và đánh giá định kỳ để đảm bảo hiệu quả của các biện pháp bảo mật.

Trong môi trường thực tế, ngoài việc thay đổi mật khẩu mặc định, hệ thống cần kết hợp thêm các cơ chế như xác thực đa yếu tố (MFA), quản lý thiết bị tập trung, giám sát nhật ký hoạt động và cập nhật firmware có xác thực chữ ký số. Việc đánh giá bảo mật nên được thực hiện định kỳ nhằm phát hiện sớm các điểm yếu mới và duy trì mức độ an toàn của hệ thống trong suốt vòng đời thiết bị IoT.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đề tài “Phân tích rủi ro của mật khẩu mặc định trên thiết bị IoT sử dụng OWASP IoTGoat” được thực hiện với mục tiêu nghiên cứu các nguy cơ phát sinh từ việc sử dụng thông tin xác thực mặc định, đánh giá mức độ ảnh hưởng đến an toàn của thiết bị IoT và đề xuất các biện pháp giảm thiểu phù hợp với các khuyến nghị hiện nay.

Trong quá trình thực hiện, đề tài đã xây dựng môi trường mô phỏng bằng Docker và OWASP IoTGoat để triển khai các kịch bản thử nghiệm. Thông qua giao diện Web quản trị và dịch vụ SSH, nhóm đã thực hiện bốn kịch bản đánh giá gồm: kiểm tra tài khoản mặc định, thay đổi mật khẩu, kiểm tra khả năng chống Brute Force và phân tích Hard-coded Credential. Các kết quả thu được đã chứng minh rằng việc sử dụng mật khẩu mặc định hoặc lưu trữ thông tin xác thực trong firmware làm gia tăng đáng kể nguy cơ truy cập trái phép và chiếm quyền điều khiển thiết bị.

Bên cạnh việc triển khai các thử nghiệm, đề tài còn xây dựng sơ đồ luồng dữ liệu (DFD), Attack Tree, ma trận STRIDE, danh mục tài sản cần bảo vệ và ma trận đánh giá rủi ro (Risk Matrix). Các mô hình này giúp phân tích mối quan hệ giữa tài sản, lỗ hổng và các mối đe dọa, đồng thời hỗ trợ xác định mức độ ưu tiên của từng rủi ro để đề xuất biện pháp giảm thiểu phù hợp.

Kết quả nghiên cứu cho thấy ba vấn đề chính ảnh hưởng đến an toàn của thiết bị IoT gồm:

- Thiết bị vẫn sử dụng tài khoản và mật khẩu mặc định, tạo điều kiện cho kẻ tấn công truy cập trái phép.
- Hệ thống không giới hạn số lần đăng nhập sai, làm tăng nguy cơ bị tấn công Brute Force.
- Thông tin xác thực được nhúng cứng (Hard-coded Credential) có thể bị khai thác nếu firmware hoặc mã nguồn bị lộ.

Để giảm thiểu các rủi ro trên, đề tài đề xuất các biện pháp như bắt buộc thay đổi mật khẩu ngay sau lần cấu hình đầu tiên, loại bỏ Hard-coded Credential khỏi firmware, áp dụng chính sách mật khẩu mạnh, giới hạn số lần đăng nhập sai, ghi nhận nhật ký truy cập và cập nhật firmware có xác thực chữ ký số. Những biện pháp này phù hợp với các khuyến nghị của OWASP IoT Top 10, OWASP IoT Security Verification Standard (ISVS) và các hướng dẫn của NIST về quản lý thông tin xác thực. Đối chiếu với các mục tiêu đề ra ở Chương 1, đề tài đã hoàn thành các mục tiêu như sau:

Mục tiêu	Mức độ hoàn thành	Minh chứng
MT-01: Phân tích nguyên nhân và điều kiện hình thành lỗ hổng mật khẩu mặc định trên thiết bị IoT	Đạt	Mục 2.3; Mục 5.2
MT-02: Xác định tài sản cần bảo vệ và đánh giá mức độ rủi ro	Đạt	Mục 5.1; Mục 5.3
MT-03: Xây dựng Threat Model, DFD, Attack Tree và ma trận STRIDE	Đạt	Chương 3; Mục 5.2
MT-04: Xây dựng các kịch bản thử nghiệm và đánh giá trên OWASP IoTGoat	Đạt	Mục 4.3; Mục 4.4

MT-05: Đề xuất các biện pháp giảm thiểu và checklist chính sách mật khẩu	Đạt	Mục 5.4
--	-----	---------

Bảng 6.1: Đối chiếu mục tiêu nghiên cứu với kết quả thực hiện.

Nhìn chung, đề tài đã hoàn thành các mục tiêu nghiên cứu đề ra, đáp ứng yêu cầu của học phần về phân tích rủi ro an toàn thông tin trên hệ thống IoT. Các kết quả đạt được không chỉ giúp làm rõ các nguy cơ liên quan đến mật khẩu mặc định mà còn cung cấp cơ sở để xây dựng các giải pháp tăng cường bảo mật trong quá trình thiết kế và triển khai thiết bị IoT

6.2. Hạn chế

Mặc dù đạt được các mục tiêu nghiên cứu, đề tài vẫn còn một số hạn chế nhất định.

Thứ nhất, toàn bộ quá trình thử nghiệm được thực hiện trên môi trường mô phỏng OWASP IoTGoat chạy trong Docker. Đây là môi trường được xây dựng với mục đích đào tạo nên chưa phản ánh đầy đủ đặc điểm phần cứng, hiệu năng và điều kiện vận hành của các thiết bị IoT thương mại.

Thứ hai, phạm vi nghiên cứu chỉ tập trung vào nhóm lỗ hổng liên quan đến quản lý thông tin xác thực, bao gồm mật khẩu mặc định, Hard-coded Credential và cơ chế xác thực. Các nội dung bảo mật khác như mã hóa dữ liệu, Secure Boot, cập nhật firmware an toàn, quản lý khóa mật mã, giao thức truyền thông bảo mật hoặc xác thực đa yếu tố chưa được triển khai trong phạm vi đề tài.

Thứ ba, việc đánh giá khả năng chống Brute Force mới dừng ở mức quan sát hành vi của hệ thống thông qua các lần đăng nhập sai liên tiếp. Đề tài chưa sử dụng các công cụ kiểm thử chuyên dụng như Hydra hoặc Medusa để đo lường hiệu quả của các cơ chế phòng chống trên quy mô lớn.

Ngoài ra, số lượng thiết bị và nền tảng được khảo sát còn hạn chế. Kết quả nghiên cứu chủ yếu dựa trên OWASP IoTGoat nên chưa thể đại diện cho toàn bộ các thiết bị IoT của nhiều nhà sản xuất khác nhau.

6.3. Hướng phát triển

Trong thời gian tới, đề tài có thể được mở rộng theo các hướng sau nhằm nâng cao tính ứng dụng và giá trị thực tiễn.

- Triển khai các kịch bản đánh giá trên thiết bị IoT thực tế như camera IP, router, thiết bị nhà thông minh hoặc gateway IoT để so sánh với môi trường mô phỏng OWASP IoTGoat.
- Nghiên cứu và tích hợp các cơ chế bảo mật nâng cao như TLS/mTLS, Secure Boot, xác thực đa yếu tố (MFA), quản lý chứng chỉ số và quản lý khóa mật mã nhằm tăng cường khả năng bảo vệ thông tin xác thực.
- Xây dựng hệ thống giám sát nhật ký đăng nhập và cảnh báo sớm các hành vi bất thường thông qua dashboard, từ đó hỗ trợ phát hiện các cuộc tấn công Brute Force hoặc truy cập trái phép theo thời gian thực.
- Mở rộng nghiên cứu sang các lỗ hổng khác trong OWASP IoT Top 10 như cập nhật firmware không an toàn, dịch vụ mạng không cần thiết, giao diện quản trị không bảo mật hoặc truyền dữ liệu không được mã hóa để có cái nhìn toàn diện hơn về an toàn của thiết bị IoT.
- Phát triển công cụ tự động kiểm tra cấu hình bảo mật và đánh giá mức độ tuân thủ checklist chính sách mật khẩu trên các thiết bị IoT, giúp hỗ trợ quản trị viên phát hiện sớm các điểm yếu và giảm thiểu sai sót trong quá trình triển khai.

- So sánh nhiều nền tảng mô phỏng và nhiều dòng thiết bị IoT của các nhà sản xuất khác nhau nhằm đánh giá sự khác biệt về cơ chế xác thực, chính sách quản lý mật khẩu và khả năng chống lại các cuộc tấn công phổ biến.

TÀI LIỆU THAM KHẢO

[1] OWASP Foundation. *OWASP Internet of Things Project*. GitHub Repository. URL: <https://github.com/OWASP/www-project-internet-of-things>. Truy cập ngày **09/07/2026**.

[2] OWASP Foundation. *OWASP IoTGoat*. GitHub Repository. URL: <https://github.com/OWASP/IoTGoat>. Truy cập ngày **09/07/2026**.

[3] OWASP Foundation. *OWASP IoT Security Verification Standard (ISVS)*. GitHub Repository. URL: <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Truy cập ngày **13/07/2026**.

[4] William Stallings. *Network Security Essentials: Applications and Standards*. 7th Edition. Pearson Education, 2023. ISBN: **9780137547474**.

[5] William Stallings. *Cryptography and Network Security: Principles and Practice*. 8th Edition. Pearson Education, 2023. ISBN: **9780135764033**.

[6] Charlie Kaufman, Radia Perlman, Mike Speciner. *Network Security: Private Communication in a Public World*. 2nd Edition. Prentice Hall, 2002. ISBN: **9780130460190**.

PHỤ LỤC

A. NHẬT KÝ ĐÓNG GÓP

Đề tài được thực hiện độc lập bởi một sinh viên, không có thành viên nhóm khác.

STT	Họ tên - MSSV	Công việc	Commit/File	Tỷ lệ (%)
1	Huỳnh Bùi Hoàng Ân – 231A010372	Xây dựng báo cáo, README, GitHub, Threat Model, Attack Tree, Asset Inventory, STRIDE, Risk Matrix, Checklist chính sách mật khẩu và slide trình bày	GitHub Repository	100%

B CHECKLIST TRƯỚC KHI NỘP

Sinh viên tự đánh dấu (X) vào ô Đạt/Chưa đạt tương ứng trước khi nộp bài chính thức.

STT	Nội dung kiểm tra	Trạng thái (Đạt / Chưa đạt)
1	Báo cáo đủ 6 phần chính, mục lục và tài liệu tham khảo.	Đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	Đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	Đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	Đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	Đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	Đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	Đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	Đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	Đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	Đạt

